

Narrativa explicativa de la Encuesta FAIR

1. Por qué otra encuesta más (y por qué esta importa)

Las organizaciones están rodeadas de encuestas como de correos de phishing: abundantes, insistentes y, en general, poco alineadas con sus prioridades reales. Esta, sin embargo, aspira a ser distinta por una razón sencilla: no pregunta si la ciberseguridad es “muy importante” (lo sabemos), sino cuánto dinero se pone en juego, cómo se calcula, y quién se atreve a mirar los números a los ojos.

El marco FAIR (Factor Analysis of Information Risk) ha puesto sobre la mesa una idea incómoda: el ciber-riesgo puede y debe expresarse en términos financieros, con distribuciones de probabilidad y pérdida esperada. Esta encuesta explora hasta qué punto las organizaciones han dejado atrás los semáforos rojo-ámbar-verde para abrazar esa cuantificación.

2. Ejes narrativos de la encuesta

2.1 Gobernanza: quién se sienta a la mesa

Las primeras preguntas no pretenden hacer un censo, sino identificar el contexto: sector, tamaño y, sobre todo, qué órganos de gobierno están expuestos a métricas de ciber-riesgo en euros. Una organización que nunca presenta pérdida anual esperada al Consejo, por muy avanzada que sea técnicamente, está conceptualmente a medio camino.

Se explora también si existe una política formal de cuantificación económica y con qué frecuencia se revisan los resultados. La hipótesis es clara: donde hay política, proceso y calendario, suele haber menos lugar para la improvisación.

2.2 Alcance: dónde llega FAIR (y dónde no)

Otra línea de investigación es el alcance real del uso de FAIR. Muchas organizaciones han hecho “uno o dos análisis FAIR” para justificar un proyecto emblemático; pocas lo han integrado en la evaluación sistemática de riesgos de IT, OT, datos personales, nube y proveedores.

Las preguntas buscan distinguir entre la adopción simbólica (para lucir en un informe) y la adopción estructural, en la que FAIR se convierte en el idioma común entre CISO, CRO y CFO.

2.3 Frecuencia y magnitud: poner números a las pesadillas

FAIR obliga a enfrentarse a dos preguntas esenciales: “¿cada cuánto podría pasar algo malo?” y “¿cuánto nos dolería?”. La encuesta indaga en cómo se estima la frecuencia de incidentes (registros, inteligencia de amenazas, modelos) y cómo se descompone la pérdida en sus componentes económicos.

El énfasis está en el uso de distribuciones y en la consideración de pérdidas secundarias, las grandes olvidadas. La organización que solo modela el coste de reposición de servidores, pero ignora sanciones, litigios y reputación, está practicando una variante muy parcial de FAIR.

2.4 Controles, materialidad y regulación: de la lista de deseos al estado de resultados

Los bloques dedicados a controles y materialidad exploran si la organización se limita a verificar la existencia de controles o si estima su impacto en la reducción de riesgo (visión FAIR-CAM), y si traduce incidentes en conceptos que entienden reguladores y auditores (visión FAIR-MAM).

Aquí la pregunta latente es: ¿se relaciona la ciberseguridad con estados financieros y obligaciones normativas de forma cuantitativa, o seguimos confiando en la magia de la “cumplimentitis” documental?

2.5 Automatización, IA y resiliencia: del Excel heroico al sistema vivo

Por último, la encuesta se asoma al grado de automatización, uso de IA y calidad de la integración con continuidad de negocio. Un proceso FAIR que vive en hojas de cálculo aisladas y se ejecuta cada dos años a regañadientes difícilmente podrá alimentar indicadores sectoriales o nacionales de forma creíble.

La ambición es detectar señales de procesos vivos: simulaciones recurrentes, modelos que se actualizan con datos, escenarios que se ensayan en ejercicios de crisis y que se traducen en decisiones de inversión.

3. Cómo leer las respuestas sin perder el humor

Los resultados de la encuesta podrán leerse en tres niveles:

- Como un espejo: hasta qué punto la organización ha pasado de la retórica de “el ciber-riesgo es estratégico” a la práctica cuantitativa.
- Como un mapa: qué dimensiones (frecuencia, magnitud, controles, materialidad, automatización) están más atrasadas.
- Como un guion: qué mensajes se pueden llevar al Consejo sin provocar desmayos innecesarios.

Es probable que muchas respuestas dibujen un panorama de transición: organizaciones que conocen FAIR, lo han usado alguna vez, pero todavía dependen fuertemente del juicio experto y de métricas técnicas no traducidas a euros. Ese diagnóstico no es motivo de vergüenza, sino de planificación.

4. De la organización al país: el potencial de agregación

Una motivación de fondo es la posibilidad de agregar resultados por sectores y territorios para construir indicadores FAIR de país. Para ello, la encuesta incluye preguntas sobre disposición a compartir datos de forma anonimizada y percepción de utilidad de indicadores sectoriales y nacionales.

En contextos como el español, con infraestructuras críticas, sectores regulados y episodios recientes de incidentes significativos, disponer de un “termómetro FAIR” nacional puede marcar la diferencia entre políticas basadas en conjeturas y políticas basadas en evidencia cuantitativa.

5. Invitación final

La encuesta no pretende coronar a nadie como campeón mundial de FAIR ni repartir suspensos públicos. Su ambición es más modesta y, a la vez, más exigente: ayudar a que cada organización se haga las preguntas correctas sobre su relación con el riesgo digital y el dinero.

Responderla con honestidad puede ser ligeramente incómodo, como mirar el extracto bancario después de las fiestas. Pero es un paso necesario para que la conversación sobre ciberseguridad deje de girar en torno a listas de controles y empiece a hablar, con números, de lo que realmente está en juego.